



AI Governance Guide for Regulated Organizations

Health Insurance Portability and Accountability Act (HIPAA)

A practical framework for governing AI tools under HIPAA requirements.

1. Regulatory Landscape for AI Under HIPAA

HIPAA does not have AI-specific rules, but existing rules apply fully to AI systems that touch PHI:

- Privacy Rule (45 CFR 164 Subpart E): Any AI that accesses, uses, or discloses PHI is subject to minimum necessary and permissible use requirements.
- Security Rule (45 CFR 164 Subpart C): AI systems that store, process, or transmit ePHI must implement administrative, physical, and technical safeguards.
- Breach Notification Rule: AI-related unauthorized access to PHI triggers breach notification obligations.
- HHS AI Guidance (2024): HHS has published guidance on responsible AI use in healthcare emphasizing transparency, equity, and safety.
- OCR focus: In recent enforcement actions, OCR has cited AI vendors as business associates and held covered entities responsible for BA oversight failures.

2. Business Associate Agreements for AI Vendors

Every AI vendor that creates, receives, maintains, or transmits PHI on your behalf is a Business Associate:

- BAA Requirement: Execute a compliant BAA before any PHI flows to an AI vendor. No BAA equals per-violation HIPAA exposure.
- BAA Must Cover: Permitted uses, prohibition on unauthorized disclosure, safeguards, breach reporting, subcontractor obligations, and return or destruction of PHI.
- AI-Specific BAA Provisions: Address model training on PHI. Many AI vendors use customer data to improve models. Your BAA must prohibit this unless you have explicit authorization.
- Annual Review: Confirm BAAs are current whenever a vendor updates their AI capabilities or data handling practices.

3. Security Rule Compliance for AI Systems

AI systems that touch ePHI must meet Security Rule requirements:

- Risk Analysis: Include AI systems in your annual Security Rule risk analysis. Assess threats specific to AI including model poisoning, data extraction, and adversarial inputs.
- Access Controls: Implement role-based access for AI systems. Log all access to ePHI by AI systems.
- Audit Controls: Maintain AI system audit logs showing who accessed what PHI, when, and for what purpose.

- Encryption: ePHI processed by AI must be encrypted in transit and at rest.
- Minimum Necessary: Configure AI systems to access only the PHI required for the specific use case.

4. AI and Clinical Decision Support

AI used in clinical contexts carries additional obligations:

- Accuracy and Bias: AI clinical decision support tools must be validated for accuracy across patient populations. Biased outputs may trigger both HIPAA and civil rights obligations.
- FDA Oversight: Some clinical AI tools are regulated medical devices under FDA Software as a Medical Device framework. Confirm regulatory status with your legal team.
- Informed Consent: Depending on use case and jurisdiction, patients may have a right to know AI is being used in their care.
- Documentation: AI-assisted clinical decisions must be documented in the medical record.

5. Breach Response for AI Incidents

AI-specific incidents that may trigger HIPAA breach notification:

- Unauthorized Model Training: If a vendor used your PHI to train an AI model without authorization, this is an unauthorized disclosure.
- Data Extraction Attacks: AI systems may be targeted to extract PHI through adversarial prompting.
- Output Leakage: AI systems that output PHI in unexpected ways require incident investigation.
- Breach Timeline: 60-day notification requirement to HHS OCR and affected individuals. State laws may impose shorter timelines.
- Response sequence: Contain, Assess whether PHI is involved, Determine breach vs. non-breach, Notify if required, Document everything.

6. HIPAA OCR Exam Preparation Checklist

Before an OCR investigation or audit, confirm you can produce:

- Executed BAAs with all AI vendors that touch PHI
- Current Security Rule risk analysis including AI system risks
- AI asset inventory with PHI data flow documentation

- Access control and audit log evidence for AI systems
- AI-specific policies in your HIPAA Privacy and Security policies
- Evidence of workforce training on AI and HIPAA obligations
- Incident response records for any AI-related privacy events
- Vendor oversight documentation including annual reviews

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/healthcare

Call us: (877) 945-7177